

Data Use Agreement

Last updated: October 2026.

1. Parties

This Data Use Agreement ("Agreement") is entered into between the pilot site identified at engagement signing ("Site") and Cardio AI Corp, operator of CardioAI Pro ("Company"), for the duration of a pilot evaluation under a signed Letter of Intent.

2. Purpose and Scope

Company will receive a de-identified or limited extract of Site's clinical data, for the sole purpose of configuring, running, and evaluating CardioAI Pro's risk-stratification outputs against Site's own patient population during the pilot term. This Agreement does not itself authorize the transfer of Protected Health Information (PHI); where PHI access is required for a given pilot, the parties' separately executed Business Associate Agreement governs that access, and this Agreement's permissions do not expand beyond it.

3. De-identification Standard

Data provided under this Agreement will be de-identified consistent with the HIPAA Safe Harbor method (45 CFR §164.514(b)(2)) or the Expert Determination method, at Site's election and confirmed in writing before the first data transfer. Company will not attempt to re-identify any individual from data received under this Agreement.

4. Permitted Uses

Company may use the data provided only to: (a) configure and run the CardioAI Pro risk-stratification pipeline against Site's cohort; (b) generate pilot scorecard metrics for review by Site and Company; and (c) support the FDA regulatory submissions referenced in Company's published Roadmap, where data is included in a form that remains de-identified. Any other use requires Site's separate written consent.

5. Data Minimization

Site will transfer only the data elements necessary for the agreed pilot scope, as specified in a data dictionary exhibit attached before the first transfer. Company will not request fields beyond that scope without written justification and Site approval.

6. Security of Transferred Data

Data in transit is encrypted (TLS). Data at rest is encrypted at the application layer before reaching storage, independent of the underlying storage backend — see the IT Security Summary for current implementation detail, including the specific gaps disclosed there.

7. Term and Duration

This Agreement is effective on the date of execution and expires at the end of the pilot term stated in the governing LOI or pilot agreement (target: 8–10 weeks from pilot start under the Clinical Pilot Program, or as otherwise stated in the site's specific pilot agreement). Renewal or extension requires a written amendment — this Agreement does

not auto-renew.

8. Return or Destruction of Data

Within 30 days of the Agreement's expiration or termination, Company will destroy or return all data received under it, including derived extracts used for pilot evaluation, and will certify destruction in writing upon Site's request. De-identified aggregate pilot metrics containing no site-identifying or patient-identifying information may be retained for the limited purpose of Company's own regulatory and business records.

9. Site Audit Rights

Site may request a written summary of how its data was used, accessed, and stored during the pilot term, and Company will respond within 15 business days.

10. Relationship to the Business Associate Agreement

Where a given pilot requires PHI access rather than de-identified data, the parties' Business Associate Agreement controls for that PHI, and this Data Use Agreement governs only the de-identified or limited data set portions of the engagement.

11. Miscellaneous

This Agreement, together with the governing LOI or pilot agreement and (where applicable) the Business Associate Agreement, constitutes the entire understanding regarding data use for the pilot. It is not a commitment to a commercial contract and does not obligate either party beyond the pilot term it covers.

12. Contact

Questions about this Agreement: invest@cardioalive.com